Risk register

T6 baseline: 2026-11-06. Risks are design judgments, not operational test results. Owner risk acceptance is PENDING unless separately recorded. Refer to the architecture, test plan and decisions. Earlier values/controls remain in Git history; current mitigations use the focused baseline.

Table 1. Document

ID	Risk / likelihood / impact	Mitigation and required evidence	Residual condition / owner
RK-01	Shared uplink/admin adapters/IPv6 expose protected assets / medium / critical	Offline start, inspected cables/bridges/routes and independent egress gate; FWT-01 mocks only	Blocks online work until exact topology approved; owner
RK-02	Installation erases data or interrupts existing services / medium / critical	Delivery/inspection, data/service inventory, exact disk approval, verified backup/recovery and console	No installation/service migration authorized in T6; owner
RK-03	Single host/disk failure loses lab/evidence / medium / high	Encrypted off-compute APP1 backup and isolated FWT-09 restore; private copies of evidence	No HA or AD/CA/host disaster-recovery claim; owner
RK-04	Guest disks/logs/temporary restore exhaust storage / medium / high	Four-VM 176 GiB guest disk plan, 336 GiB total provisional ledger, 80 GiB free reserve; measure usable space and rotate logs	Ordered disk not assumed installed; temporary recovery capacity needs verification; engineer
RK-05	Ordered CPU/cooler/NIC/SSD/adapter incompatible or undelivered / medium / high	Receipt/physical inspection, vendor compatibility and private part identity; distinguish five hardware statuses	W-2145 cooler/firmware and storage fit unverified; no automatic upgrade; owner
RK-06	Tailscale defaults/additive grants or overlay bypass broaden access / medium / critical	Separate lab tailnet, pre-enrollment narrow policy, APP1 TCP 443, inspect effective host/vendor rules and FWT-06	OPNsense may not see overlay; cached state/provider limits remain; engineer
RK-07	CA key compromise or lab root escapes approved clients / medium / high	One encrypted offline CA key, restricted APP1 key, lab-only public trust and FWT-05	No HSM, certificate revocation service or enterprise lifecycle; owner
RK-08	DNS/time/host dependencies break identity or enable bypass / medium / high	Lab DNS/time only, named required services, same-zone host rules, FWT-02/03/04	No claim that a port block defeats every DNS-over-HTTPS fallback; engineer
RK-09	Public artifact/history leaks secret/private record / medium / critical	Private raw records, candidate /staged/history/metadata review and focused scanner, FSC-10	Scanners are bounded; publisher manually reviews all artifacts

ID	Risk / likelihood / impact	Mitigation and required evidence	Residual condition / owner
RK-10	Evaluation/provider terms, activation or MFA feature unavailable / medium / high	Verify current lawful terms/deadlines/features at stage entry; record gaps	No purchase, corporate key or unsafe activation workaround; owner
RK-11	Five-event manual sample misses wider attacks/log loss / medium / medium	Relevant source/UTC/access/rotation review, five distinct events and investigation, FWT-07	No SIEM coverage, ingestion SLA or extended-retention claim; engineer
RK-12	Plans, templates or sample evidence are mistaken for verified implementation / medium / high	Empty actual fields, named cutoffs, precise test verdicts and separate UAT	No compliance/certification/business-savings claim; technical lead
RK-13	Altered media/dependency or offline patch lag / medium / high	Official integrity/version checks, approved update path, pinned least-privilege CI	Pinning/version list alone does not prove safety; engineer
RK-14	Hypervisor/admin compromise defeats virtual controls / low-medium / critical	Dedicated admin path, supported MFA, console recovery, physical separation	One host/operator; owner decides residual risk
RK-15	Procedural PR convention bypassed without enforcement / medium / medium	Branch/PR/exact-head CI and actual rule/review inspection	Rulesets/review settings remain explicit owner decisions
RK-16	Restore reconnects duplicate identity or damages sole backup / medium / high	APP1 original off, restored NICs disconnected/Tailscale inactive, backup preserved, FWT-09	Supported AD/CA recovery excluded from this drill; engineer
RK-17	Existing public commits contain non-noreply metadata / observed historical privacy finding	Preserve existing history; verify both fields on every new commit/merge	Separate owner approval required for any history/privacy remediation
RK-18	Generated PDFs drift/clip/lose topology or links / medium / medium	Pinned deterministic build, source/output hashes, text/navigation checks and visual QA	Extraction alone cannot establish layout; documentation maintainer
RK-19	Report links/history break during maintenance / medium / medium	Preserve frozen reports/archives and compatibility aliases; validate both historical locations	No report-content rewrite; documentation maintainer
RK-20	Legacy shell/current submission mismatch / T7 migration implemented; verification recorded separately	Five active four-week templates replace verified blank T5 files through history-preserving Git changes; T7 report records native, content and publication evidence	Historical links use the original T5 snapshot; completed lab records/owner acceptance remain pending, owner
RK-21	Manual AD/app role mapping leaves stale access / medium / high	Different passwords, explicit dual-record change, six cases and app revocation in FWT-03	No automatic AD SSO/group propagation; engineer records every lifecycle change

ID	Risk / likelihood / impact	Mitigation and required evidence	Residual condition / owner
RK-22	Delivery/readiness/approval consumes four-week window / medium / medium	Start working weeks after prerequisites, keep 8-12 hours/week estimate and defer dependent work honestly	Dates need revision if blockers remain; owner

1. Handling and escalation

Resolve blocking risk before dependent work. Record new triggers, owner, severity, mitigation/evidence and residual acceptance. Unexpected protected connectivity, uncertain destructive targets, exposed secrets or missing recovery stop the affected work. Use approved isolation, preserve private evidence and obtain exact owner scope before further change. No implementation, procurement, license selection or risk acceptance is implied.